

Systém na podporu vypracovania bezpečnostných projektov pre malé ISVS

Anton Kica

Školiteľ

doc. RNDr. Daniel Olejár, PhD

9. júna 2024

The internet is about to start killing people, and the government regulates things that kill people.

Bruce Schneier

Informatizácia spoločnosti

Všetko to začalo informatizáciou spoločnosti:

- ▶ technologický pokrok a digitalizácia informácií,
- ▶ spracováva sa veľké množstvo údajov,
- ▶ používajú sa digitálne informačné a komunikačné technológie (d-IKT),
- ▶ informačné systémy sú vystavené rôznym hrozbám v tzv. kybernetickom priestore.

Potreba chrániť d-IKT

Vznikla prirodzená potreba chrániť d-IKT, bol vytvorený právny podklad:

- ▶ 2016 prijala Európska únia smernicu NIS (2016/1148) o kritickej infraštruktúre,
- ▶ 2018 prijala NRSR zákon o kybernetickej bezpečnosti (69/2018 Z. z.),
- ▶ 2019 prijala NRSR zákon o informačných technológiách vo verejnej správe (95/2019 Z. z.).

Čo to je kybernetická a informačná bezpečnosť?

Kybernetická a informačná bezpečnosť je multidisciplinárna oblasť ľudskej činnosti[7], ktorá skúma:

- ▶ hrozby voči informáciám, informačným systémom a sieťam,
- ▶ riešenia eliminácie riziká a hrozieb,
- ▶ metódy dlhodobej a efektívnej ochrany aktív organizácie.

Prečo by nás mala zaujímať KIB?

Dôvodov je mnoho, najmä zaručiť:

- ▶ dôvernosc, integritu a dostupnosť informácie a informačných systémov,
- ▶ spoľahlivosť systémov a spracovanej informácie,
- ▶ bezpečnosť okolitých systémov.

Prečo sa musíme zaujímať KIB?

V prípade, že ste prevádzkovateľom informačného systému vo verejnej správe Vám to prikazujú:

- ▶ 69/2018 Z. z., zákon o kybernetickej bezpečnosti,
- ▶ 95/2019 Z. z., zákon o informačných technológiách vo verejnej správe

Zákon o kybernetickej bezpečnosti

- ▶ kompetenčný zákon, *lex generalis*,
- ▶ prevádzkovateľ základnej služby,
- ▶ rámcovo určuje 16 oblastí, pre ktoré má prevádzkovateľ prijať bezpečnostné opatrenia,
- ▶ určenie manažéra kybernetickej a informačnej bezpečnosti,
- ▶ upravuje povinnosti tretích strán,
- ▶ vyhláška 362/2018 Z.z. – rozsah bezpečnostnej dokumentácie, kategorizácia sietí a informačných systémov.

Zákon o informačných technológiách vo verejnej správe

- ▶ *lex specialis*, sektor verejná správa, podsektor informačné systémy,
- ▶ správca informačného systému verejnej správy,
- ▶ zavedenie systému riadenia informačnej bezpečnosti,
- ▶ možnosť postupovať pomocou medzinárodných štandardov,
- ▶ vyhláška 179/2020 Z.z. – obsah bezpečnostnej dokumentácie a kategorizácia.

To najdôležitejšie z právnych predpisov

- ▶ určenie manažéra kybernetickej a informačnej bezpečnosti,
- ▶ zavedenie systému riadenia informačnej bezpečnosti.

Všetko vyzerá byť jasné, kde je
problém?

Všetko vyzerá byť jasné, kde je problém?

- ▶ požiadavky sú rozsiahle aj pre malého správcu ISVS,
- ▶ nedostatok kvalifikovaných odborníkov,
- ▶ potreba systematického riešenia.

Pomocný systém pre manažéra KIB

Pomocný systém

Pomocný systém manažérovi KIB:

- ▶ objasní, prečo sa musia v organizácii zaoberať KIB,
- ▶ poskytne minimálne znalosti KIB,
- ▶ vysvetlí a prevedie ho procesom zavádzania ISMS,
- ▶ pomôže mu zozbierať informácie na vypracovanie bezpečnostnej dokumentácie.

Medzinárodné štandardy a metodiky

- ▶ séria štandardov ISO/IEC 27000
 - ▶ ISO/IEC 27001[4]
 - ▶ ISO/IEC 27002[5]
- ▶ metodiky BSI
 - ▶ BSI Standard 200-1[1]
 - ▶ BSI Standard 200-2[2]
 - ▶ BSI Standard 200-3[3]
 - ▶ IT-Grundschutz Compendium[6]

Návrhnutý a implementovaný systém

Teraz si prejdeme systémom a ukážeme niektoré z jeho častí.

Úvodná stránka

Otázka: Prečo sa naša organizácia musí zaoberať kybernetickou a informačnou bezpečnosťou?

Otázka: Ktoré bezpečnostné opatrenia musíme zaviesť podľa ZoKB a ZoITVS?

Otázka: Je toho veľa, ako vieme splniť všetky legislatívne požiadavky?

Začíname

Úvodná stránka

Ahoj! Som Systém, program vyvinutý na fakulte Matematiky fyziky a informatiky Univerzity Komenského. Mojou úlohou je Vám pomôcť pri plnení povinností, ktoré pre Vašu organizáciu vyplývajú z nasledujúcich zákonov:

	Skratka	Odkaz na SloVLex
Zákon o kybernetickej bezpečnosti	ZoKB	69/2018 Z. z.
Zákona o informačných technológiach verejnej správy	ZoITVS	95/2019 Z. z.

Tieto zákony Vám ukladajú povinnosti v oblasti kybernetickej a informačnej bezpečnosti (KIB), ktoré ste povinný splniť – súčasne ako prevádzkovateľ základnej služby (podľa ZoKB) a správca informačných technológií verejnej správy (podľa ZoITVS).

Otázka: Prečo sa naša organizácia musí zaoberať kybernetickou a informačnou bezpečnosťou?

Základným dôvodom je dosiahnuť aspoň základnú úroveň ochrany Vašich systémov a údajov. Ochraňovať ich musíte, aby ste počas svojej každodennej práce:

- mohli spoľahlivo používať Vaše systémy a spracovávať informácie,
- pracovali s pravdivými a konzistentnými údajmi a
- aby ste neohrozovali okolité systémy, na ktoré ste pripojení alebo sa pripájajú na Vás.

Ďalším dôvodom sú legislatívne požiadavky, keďže:

Vaša organizácia bola zaradená do registra prevádzkovateľov základných služieb.



Vaša organizácia je prevádzkovateľom základnej služby.



Vaša organizácia je orgánom riadenia.



Vaša organizácia je správcom informačných technológií verejnej správy (ITVS) a prevádzkovateľom informačného systému verejnej správy



Zavádzanie ISMS

1. Oficiálne informácie
2. Určenie stavu organizácie
3. Formulovanie všeobecných cieľov KIB a určenie úrovne KIB
4. Akvizícia aplikácií, IT systémov a miestností
5. Vysokoúrovňovná analýza rizík
6. Hrozby
7. Riziká
8. Bezpečnostné opatrenia
9. Formovanie organizačnej štruktúry
10. Bezpečnostné princípy
11. Pred spísaním politiky
12. Politika KIB

Úvod

Formulovanie
všeobecných cieľov KIB

Určenie úrovne KIB

Sformuluj nový všeobecný cieľ KIB

Znenie cieľa

Chránené hodnoty KIB: ☐ dôvernosť ☐ integrita ☐ dostupnosť

Ulož cieľ

Tabuľka všeobecných cieľov KIB

Znenie cieľa

Chránené hodnoty KIB

Vysoká spoľahlivosť a kvalita spracovávania informácie.

integrita, dostupnosť, dôvernosť

Vymaž

Ochrana fyzických osôb, ich zdravie a osobné údaje.

Vymaž

Určenie úrovne KIB biznis procesov

Podobne ako všeobecné ciele KIB, určenie úrovne KIB biznisových procesov vo vzťahu k základným bezpečnostným hodnotám (dôvernosť, integrita a dostupnosť) Vám pomôže lepšie definovať a zaviesť vhodné bezpečnostné opatrenia.

Budeme rozlišovať tri rôzne úrovne KIB: základná, stredná a vysoká. Následne rozoberieme rôzne odôvodňovania/kritéria pre zaradenia do jednotlivých úrovní.

Základná úroveň KIB

Chránená informácia je buď verejná alebo je určená na interné použitie.

Informácia by mala byť správna.

Malé chyby sú prípustné, ale sú rozpoznateľné alebo sa im dá vyhnúť.

Dlhá nedostupnosť informácie je neprijateľná.

Ochrana osobných údajov musí byť zaistená.

Zodpovednosť

Slabé miesta

Bezpečnostné opatrenia

Bezpečnostné opatrenia

Dobre oboznámenie nových zamestnancov

Personálne oddelenie a nadriadení MUSIA zaistiť, aby noví zamestnanci boli dostatočne informovaní o náplni a úlohách ich pracovného pomeru. ^

Ideálne krátke stretnutie s vedúcim oddelenia, ktorý nového zamestnanca oboznámi o potrebných dokumentoch a poskytne mu potrebné informácie. Ak sa nový zamestnanec ocitne sám, bez vedenia druhého zamestnanca, zoči-voči širokému množstvu informácií, môže ho to premôcť a v konečnom dôsledku bude odrazený dokumenty študovať.

Zamestnanci MUSIA BYŤ informovaní o existujúcich regulačných predpisoch, pravidlách, inštrukciách a procedúrach v organizácii. ^

Treba zorganizovať hromadné stretnutia alebo školenia, kde sa vhodne oboznámia o dokumentoch. Nástenky, oznamy alebo iné odkazy k dokumentom bude potrebné vypracovať/vystaviť, aby si ich zamestnanci vedeli aj sami vyhľadať.

Kontaktná osoba/mentor BY MALA BYŤ ustanovená pre rôzne oblasti činností organizácie. ^

Znalá osoba môže ľahko pomôcť novým ľuďom sa zorientovať, začúť, správne nasmerovať alebo aj pomôcť koordinovať kolegov.

Zavedenie procedúr pre odchádzajúcich zamestnancov

Nástupca odchádzajúceho zamestnanca MUSÍ BYŤ včasne oboznámený o svojich pracovných povinnostiach. ^

Ideálne by svojho nástupcu mal zaučiť odchádzajúci zamestnanec. Ak ste ešte nenašli náhradu, odchádzajúci zamestnanec MUSÍ pripraviť detailnú dokumentáciu, aby nový zamestnanec vedel čím skôr prebrať jeho zodpovednosti.

Odchádzajúci zamestnanci MUSIA odovzdať späť všetky zariadenia potrebné na výkon svojej práce. ^

Predmety ako vstupné karty, čipy, odznaky, autorizačné zariadenia, pracovné nástroje, notebooky, mobily, prenosné pamäťové média a ďalšie.

Úvod

Určenie úrovne rizík

občas

niekoľkokrát v priebehu roka

veľmi často

niekoľkokrát za mesiac

ťažkosť

značný

problematické fungovanie organizácie, ohrození sú ľudia alebo majetok

kritický

existencia organizácie je ohrozená, dopad na sektor a okolie, vážne dopady na zdravie/bezpečnosť ľudí a na majetok

Výsledkom je matica klasifikácie rizika:

dopad

kritický	stredné	vysoké	vysoké
značný	nízke	stredné	vysoké
zanedbateľný	nízke	nízke	nízke
	zanedbateľná	občas	veľmi často
			pravdepodobnosť

Určte pravdepodobnosť výskytu a úroveň dopadu hrozby

hrozby	pravdepodobnosť výskytu hrozby	úroveň dopadu hrozby	klasifikácia rizika
zamestnanci, ľudské chyby a omyly	občas	kritický	vysoká
krádež	zanedbateľná	značný	nízka

Vypočítaj riziká.

Aká je úroveň akceptovateľného rizika pre Vašu organizáciu?

stredná

Ulož

Identifikácia, pôsobnosť
a obsah Politiky KIBDeklarácia Vedenia OÚB
o význame a podpore
KIB

Základné princípy

Riadenie KIB vo OÚB

Správa rizík

Personálna bezpečnosť

Riešenie kybernetických
bezpečnostných
incidentovSchválenie,
implementácia a správa
Politiky KIB

Povinnosť spísať politiku KIB Vám ako súčasť ISMS ukladá ZoITVS v [§ 19 odseku 1 písmene a](#).

Politika KIB

Identifikácia, pôsobnosť a obsah Politiky KIB

Tento dokument je Politika kybernetickej a informačnej bezpečnosti organizácie Obecny úrad Bubble-bum (Politika KIB OÚB). Politika KIB OÚB bola vypracovaná v súlade s požiadavkami 69/2018 Z. z. (zákon o kybernetickej bezpečnosti) a 95/2019 Z. z. (zákon o informačných technológiách vo verejnej správe). Využíva BSI štandardy BSI 200-1, BSI 200-2, a IT-Grundschutz kompendium, ktoré sú kompatibilné s požiadavkami zákonov.

Politika KIB OÚB sa vzťahuje na informácie OÚB, informačné systémy a počítačové siete v správe OÚB a kladie bezpečnostné požiadavky na externé systémy, ktoré komunikujú s informačnými systémami v správe Obecny úrad Bubble-bum.

Politika KIB OÚB sa nevzťahuje na informačné systémy a počítačové siete OÚB, ktorých ochranu upravujú iné zákony, ako tie, ktoré sú uvedené vyššie.

Politika KIB OÚB je verejný dokument a vzťahuje sa na všetkých ľudí (zamestnancov OÚB, poskytovateľov služieb, dodávateľov, tretie strany, občanov, klientov a pod.), ktorí majú prístup k informačným systémom a informáciám OÚB a svojou činnosťou môžu (v pozitívnom alebo negatívnom zmysle) ovplyvniť kybernetickú a informačnú bezpečnosť OÚB.

Deklarácia Vedenia OÚB o význame a podpore KIB

OÚB je obecny úrad, ktorá na základe 369/1990 Zb. o obecnom zriadení plní nasledujúce úlohy spravujeme matriku, schvaľujeme rozpočet. OÚB plní tieto úlohy prostredníctvom agend a činností 369/1990 Zb. o obecnom zriadení.

Pri plnení hlavných úloh a zabezpečovaní vlastnej činnosti OÚB využíva informácie, ktoré spracováva pomocou informačných systémov, počítačových sietí a iných zariadení digitálnych informačných a komunikačných technológií (d-IKT).

Zabezpečenie primeranej ochrany aktív OÚB (zaistenie a udržiavanie primeranej/dostatočnej úrovne kybernetickej a informačnej bezpečnosti) je nutným predpokladom toho, aby OÚB mohla plniť svoje poslanie a každý, kto má prístup k informačným aktívam OÚB, musí dodržiavať ustanovenia Politiky KIB a podieľať sa spôsobom zodpovedajúcim jeho pracovnému zaradeniu na plnení úloh KIB. Za hlavné ciele kybernetickej a informačnej bezpečnosti vo OÚB Vedenie OÚB považuje:

- Vysoká spoľahlivosť a kvalita spracovávaní informácie.
- Ochrana fyzických osôb, ich zdravie a osobné údaje.

Vedenie OÚB preto považuje zaistenie primeranej úrovne kybernetickej a informačnej bezpečnosti OÚB za trvalú úlohu s najvyššou prioritou a zaväzuje sa na plnenie tejto úlohy vytvoriť na OÚB primerané právne, organizačné, technické, materiálne aj finančné podmienky.

Zoznamy

[Všeobecné
informácie](#)

[Výsledky
vysokoúrovňovej
analýzy rizík](#)

[Biznisové
procesy](#)

[Aplikácie](#)

[IT systémy](#)

[Miestnosti](#)

[Bezpečnostné
ciele](#)

Výsledky vysokoúrovňovej analýzy rizík

Hlavné aktíva

Hlavné primárne aktíva

Matrika

Hlavné sekundárne aktíva

informácia

zamestnanci

Hrozby a riziká

hrozby	pravdepodobnosť výskytu hrozby	úroveň dopadu hrozby	klasifikácia rizika
zamestnanci, ľudské chyby a omyly	občas	kritický	vysoká
krádež	zanedbateľná	značný	nízka

Úroveň akceptovateľného rizika: **stredná**

Zhrnuté: Čo sa nám podarilo?

- ▶ vysvetlili sme manažérovi KIB jeho povinnosti,
- ▶ uviedli a vysvetlili sme problematiku KIB manažérovi KIB,
- ▶ získali sme od manažéra KIB informácie potrebné na vypracovanie KIB.

Ďalšia práca

- ▶ systém nie je kompletný, je čiastočne implementovaný,
- ▶ kontrola postupu zavádzania ISMS,
- ▶ venovali sme sa zatiaľ iba zavádzaniu ISMS,
- ▶ väčšia funkcionálna a pomoc manažérovi.

zdroje

- [1] *BSI Standard 200-1.* 2017.
- [2] *BSI Standard 200-2.* 2017.
- [3] *BSI Standard 200-3.* 2017.
- [4] *ISO/IEC 27001.* 2022.
- [5] *ISO/IEC 27002.* 2022.
- [6] *IT-Grundschutz-Compendium.* 2022.
- [7] *Krátky úvod do informačnej a kybernetickej bezpečnosti a Malý výkladový slovník.* https://mirri.gov.sk/wp-content/uploads/2022/02/KB-K1_2_3-uvod-do-KIB_slovník_ver1.1.pdf.

Koniec

Ďakujem za vašu pozornosť.

Posudky



priestor na otázky